QRshield ■■ — Project Summary

A Three-Layer Detector for Malicious & Tampered QR Codes (Quishing)

Course: Cryptography & Network Security (CE305 / CS305) | **Evaluation:** ISE-2
College: Sardar Patel Institute of Technology (SPIT), Mumbai
Team: Black Sparrow (10 Members) | **Team Lead:** Akshit Sharma

Status: Working End-to-End System with 49 Passed Tests	**Key Idea: Check Link (ML) + Check Physical Sticker (CV) + Verify Signature (Crypto)**

1. The Problem in Simple Words

When people scan QR codes on phones, the phone **blindly opens the website or payment app**. Scammers exploit this trust through **Quishing (QR Phishing)**:

- **Fake / Zero-Day Links:** Scammers make brand-new lookalike sites (e.g. *phonepe-refund.xyz*) that antivirus blocklists haven't seen yet.
- **Physical Sticker Swapping:** Scammers print paper/vinyl stickers and paste them over real QR codes on parking meters, restaurant stands, or shop UPI soundboxes. **Online link scanners cannot see the physical sticker!**
- **No Proof of Origin:** Anyone can print a QR code claiming to be a bank or college because standard QR codes have no digital signatures.

2. What We Have Done (The 3-Layer Solution)

Instead of 'scan and auto-open', QRshield does **'scan, verify, then decide'** using 3 simple checks:

Layer	What it Does (Simple Explanation)	Result / Output
1. Link Check (ML)	Inspects the URL for brand typos (e.g. 'ph0nepe'), suspicious new extensions (.xyz), and malicious patterns without opening the page.	Safe or Fake URL score
2. Camera Check (CV)	Analyzes the photo to see if someone physically pasted a sticker over the original board. Looks for cut edges, small shadows, and highlights them in red on a heatmap.	Sticker Tamper score + Heatmap
3. Digital Signatures	Authentic businesses (like smart city parking) digitally sign their QR code. If the signature matches our verified root authority, it gives a green Verified badge.	Valid / Fake / Unsigned badge
4. Decision Engine	Combines all 3 checks. Never opens the link automatically. Shows a clear Green (SAFE), Yellow (SUSPICIOUS), or Red (BLOCK) screen.	SAFE / SUSPICIOUS / BLOCK banner

3. Technologies Used (High-Level Overview)

Area	Technology / Tool	Why We Used It (Plain Reason)
Programming	Python 3.12	Simple, fast to build with, and standard for AI and security projects.
Cryptography	Ed25519 (PyCA Cryptography)	Very small 64-byte signature that fits neatly inside a QR code without making it dense or hard to scan.
Computer Vision	OpenCV & Pillow	Industry standard for reading camera pictures and finding sticker edges and cutlines.
Machine Learning	LightGBM & Scikit-Learn	Lightweight AI that runs in under 3 milliseconds to spot fake links instantly.
Web Server	FastAPI & Uvicorn	Fast, modern Python web server to connect the scanner to our backend.
Frontend / UI	HTML, CSS, JavaScript (Vanilla)	Runs right in any phone or laptop browser with camera access without installing bulky software.
Database & Testing	SQLite & Pytest	Lightweight storage for certified keys; 49 automated tests to ensure everything works.

4. How to Present in Front of Your Professor (Simple Guide)

Keep your presentation around **5 to 7 minutes**. Speak confidently and follow these 4 simple steps:

Step 1: The Problem (1 Min):

'Good morning Professor. We are Team Black Sparrow. Our project is QRshield. When people scan QR codes, their phones open the website without checking. Fraudsters paste physical stickers over real parking meters or send fake payment links. Antivirus can't see physical stickers. That's why we created QRshield.'

Step 2: How QRshield Solves It (1.5 Min):

'We check 3 things in parallel before anything opens: First, AI checks the URL for scams. Second, Computer Vision looks at the camera feed to see if a sticker is pasted over the board, lighting up cutlines in red. Third, for official organizations, we check a digital cryptographic signature. If all checks pass, it's SAFE. If tampered, it's BLOCKED.'

Step 3: Live Demo (2 Min):

Show the web app on your laptop (or run run_demo.bat) and click the test buttons:

- **1. Clean Unsigned:** SPIT College link → Shows **SAFE (Green)**. Explains normal codes aren't blocked.
- **2. Phishing URL:** Lookalike link → Shows **BLOCK (Red)**. Caught by URL AI.
- **3. Signed City Parking:** Real parking QR → Shows **SAFE with 'QRSHIELD CERTIFIED' Badge**.
- **4. Sticker Swap:** Sticker pasted on meter → Shows **SUSPICIOUS** with red heatmap on sticker edges.
- **5. Forged Token:** Fake signature → Shows **BLOCK**. Crypto caught the fake key.

Step 4: Conclusion & Tests (1 Min):

'The entire scan runs in less than 0.7 seconds. We have 49 automated unit tests covering security and attack scenarios, all passing.'

5. Likely Questions the Professor Will Ask (Cheat Sheet)

Q1: Why use digital signatures inside QR codes?
Ans: Because anyone can print a fake QR code claiming to be official. A digital signature gives mathematically unbreakable proof of who created the QR code.

Q2: What if someone copies a real signed QR code and pastes it elsewhere?
Ans: We include the merchant's location ID and an expiry time inside the code, plus our camera layer (CV) checks if it's pasted as a sticker.

Q3: Why not just use Google Safe Browsing?
Ans: Google only knows a bad link hours or days after victims report it. It misses brand-new scams registered today, and it cannot see physical stickers on a wall.

6. Future Plans (What Can We Do to Make This Better?)

- **Native Mobile App:** Build a direct Android & iOS camera app so users don't need a browser to scan.
- **100% Offline On-Device AI:** Run the camera and URL checks directly inside the phone without sending images to a server.
- **Dynamic Rotating QR Codes:** Support moving QR codes (like OTPs that change every 30 seconds) on shop billing screens so nobody can screenshot or reuse them.
- **UPI Payment App Partnerships:** Integrate directly into Google Pay, PhonePe, and Paytm to verify merchants before money is transferred.
- **Public Trust Registry:** Allow municipalities and verified stores to register their public keys in an open public ledger.